

PCI DSS V4.0 COMPLIANCE & NETWORK SEGMENTATION POLICY	
Policy Owner:	Security Operations & Governance
Author:	Morolake Bolarinwa
Version:	1.0 (Final)
Effective Date:	September 2026

1. EXECUTIVE SUMMARY

Payment Card Industry Data Security Standard (PCI DSS) v4.0 introduces stringent requirements for continuous security and customized authentication. This policy outlines the governance and technical controls required to secure the Cardholder Data Environment (CDE), focusing on scope reduction through network segmentation, strict Identity and Access Management (IAM), and continuous audit logging.

The objective is to ensure that all systems transmitting, processing, or storing cardholder data are isolated and monitored in absolute compliance with PCI DSS v4.0.

2. SCOPE & APPLICABILITY

This policy applies to all personnel, systems, and hybrid-cloud infrastructure components that interact with the CDE.

- In-Scope (CDE):** Payment processing servers, databases storing PAN (Primary Account Number), and administrative jump servers.
- Out-of-Scope:** Corporate workstations and non-payment enterprise applications, effectively isolated via strict VLAN segmentation and firewall rules.

3. CORE POLICY REQUIREMENTS (MAPPED TO PCI DSS V4.0)

Requirement 7: Restrict Access to Cardholder Data by Business Need-to-Know

- 7.2.1:** Access to the CDE is strictly governed by Role-Based Access Control (RBAC).
- Implementation:** Entra ID is utilized to enforce "least privilege." Users are only granted access to CDE components if their active job responsibilities require it. Access is reviewed quarterly.

Requirement 8: Identify Users and Authenticate Access to System Components

- 8.4.2 & 8.5.1:** Multi-Factor Authentication (MFA) is strictly enforced for all access into the CDE.

- **Implementation:** Microsoft Entra ID Conditional Access policies dictate that any administrative access to the CDE requires phishing-resistant MFA. Shared or generic accounts are strictly prohibited. Privileged access requires Just-In-Time (JIT) elevation via Privileged Identity Management (PIM).

Requirement 10: Log and Monitor All Access to System Components and Cardholder Data

- **10.2.1:** All individual user access to cardholder data must be logged.
- **Implementation:** Microsoft Sentinel (SIEM) is configured to ingest all access logs, authentication attempts (success/fail), and administrative actions within the CDE.
- **10.5.1:** Audit trails are secured from alteration. Log files are retained for at least one year, with three months immediately available for analysis.

Requirement 11: Protect Security of Systems and Networks Regularly

- **11.3.1:** Internal and external vulnerability scans must be performed at least quarterly.
- **Implementation:** Vulnerability management tools are configured to scan the CDE weekly. Any critical vulnerabilities (CVSS 8.0+) discovered in the CDE must be patched within 15 days.

4. INCIDENT RESPONSE & POLICY ENFORCEMENT

Any circumvention of segmentation controls or unauthorized attempts to access the CDE will trigger an immediate high-severity alert in the SIEM and result in automated account suspension. The Governance, Risk, and Compliance (GRC) team conducts biannual reviews of this policy to ensure alignment with evolving PCI DSS v4.0 standards.